Research Integrity

ORCID's Privacy Policy, November 13 2024

Ellen Paterson, Data Protection Officer

- ORCID and Privacy: some history
- The Data Protection Officer role
- Developing the ORCID Privacy Framework
- The ORCID Privacy Policy
- Individual data protection rights
- Privacy and Security at ORCID
- What’s next?
- Questions

POLL: How would you rate your data protection knowledge?

A. Expert level. I am (or could be) working in this field
B. Pretty good. I know my way round the law as it applies to my work
C. It's okay. I understand the essentials
D. It's not my area of expertise but I have an interest

Privacy

'...Refers to an individual's right to control their personal information.'

Privacy extends beyond data; it is about personal control, autonomy and the protection of one's private life. It is about the ability to maintain confidentiality in various aspects of life, whether that's in personal communications, family matters, or professional interactions.'

Data Protection

Arguably more of a European concept, Data Protection:

'...Refers to the legal obligations and measures that organisations must implement to safeguard personal data from misuse, loss, or unauthorised access.' (PropelFwd)

ORCID and Privacy: some history

Everything we do is guided by our values and founding principles

Our Values

Our Founding Principles

1. ORCID will work to support the creation of a permanent, clear, and unambiguous record of research and scholarly communication by enabling reliable attribution of authors and contributors.
2. ORCID will transcend discipline, geographic, national, and institutional boundaries.
3. Participation in ORCID is open to any organization that has an interest in research and scholarly communications.
4. **Access to ORCID services will be based on transparent and non-discriminatory terms posted on the ORCID website.**
5. **Researchers will be able to create, edit, and maintain an ORCID identifier and record free of charge.**
6. **Researchers will control the defined privacy settings of their own ORCID record data.**
7. **All data contributed to ORCID by researchers or claimed by them will be available in standard formats for free download (subject to the researchers' own privacy settings) that are updated once a year and released under a CC0 waiver.**
8. All software developed by ORCID will be publicly released under an Open Source Software license approved by the Open Source Initiative. For the software it adopts, ORCID will prefer Open Source.
9. **ORCID identifiers and record data (subject to privacy settings) will be made available via a combination of no-charge and for-a-fee APIs and services.** Any fees will be set to ensure the sustainability of ORCID as a not-for-profit, charitable organization focused on the long-term persistence of the ORCID system.
10. ORCID will be governed by representatives from a broad cross-section of stakeholders, the majority of whom are not-for-profit, and will strive for maximal transparency by publicly posting summaries of all Board meetings and annual financial reports.

ORCID and the General Data Protection Regulation (GDPR)

In 2016, a new European data protection law was announced which would be in force from 2018.

- The GDPR was - arguably still is - the world's most comprehensive data protection law
- Strengthened people's rights, and introduced new legal obligations for 'data controllers' in Europe and beyond
- ORCID adopted GDPR requirements in full, taking extensive actions in preparation for the 2018 GDPR enforcement date
- This initial work was revisited in 2021-22, with the aim of ensuring any compliance gaps were addressed

Thinking beyond the GDPR

GDPR enables us to ‘aim high’ and demonstrate compliance with an internationally-recognised privacy standard, however;

- ORCID is a US-based organisation, not European
- ORCID services are offered worldwide and we have an international staff, so we need to look at privacy laws around the globe
- Privacy and data protection laws are changing. While many are similar to the GDPR, there are nuances to be aware of - particularly in the United States
- Transfer of personal data across borders brings additional privacy complications
- Security of data has become an even greater concern over time

Other ways we demonstrate our commitment to privacy

The ORCID Trust Framework

The ORCID Trust Program provides greater transparency into the components that are foundational to our principles:

- Individual control
- Reliability
- Accountability
- Integrity

TRUSTe certification

ORCID is a participant in TRUSTe's Verified International Privacy Program (run by TrustArc). See our Privacy Seal

This seal confirms our governance and privacy practices comply with the TrustArc requirements, which are based on the EU–US Data Privacy Framework requirements.

Through ongoing security improvements

By having a dedicated Data protection officer…

The Data Protection Officer role at ORCID

A little bit about me

- Over 20 years of experience in information management and governance
- Former academic librarian
- Over 12 years of data protection experience, focused on EU and UK law
- Led on GDPR implementation and improvement for two UK universities
- Worked alongside security and technology experts, as well as researchers

All of which meant that ORCID ‘made sense’ to me when I joined a year ago. Although organisations are always more complex than they first appear and ORCID is no exception…

What are some benefits of ORCID having a DPO?

In-house expertise

ORCID already makes good use of external legal and sector experts but having a data protection specialist in-house improves efficiency and responsiveness

Prioritisation of a compliance framework approach

Having a DPO means that we can be consistent and make incremental, structured improvements over time, following a recognised privacy framework

Keeping on top of global privacy changes

Data protection and privacy laws are developing rapidly. Having a DPO means we can keep on top of these and update our practices to meet our legal obligations

Developing the ORCID Privacy Framework

Privacy at ORCID

The **problem**

Overall, good data protection practices and a privacy-focused culture, BUT

- Compliance progress was project-led
- Initiatives sometimes ad hoc and not always joined up
- Not easy to evidence
- Complex global landscape

The **solution**

Investigate and select a recognised an appropriate privacy/data protection framework to provide structure to ORCID's privacy work and make it easier to evidence

Privacy Framework / Requirements

- Not looking for a ‘tick box’ approach
- Needed to be customisable, with defined outcomes. We wanted a toolkit that would help us prioritise tasks based on ORCID’s circumstances
- Preferably not aligned to specific legislation, but from a reputable source
- Framework should make it easy for us to see, and demonstrate to others, progress against our specific goals over time

POLL: Have you introduced a privacy framework in your organisation?

A. Yes, it works well for us
B. Yes, but it hasn't been widely adopted or fully implemented
C. No, we're considering it though
D. No, I don't think we need one

Outcome: The NIST framework

"The NIST Privacy Framework is a voluntary tool developed in collaboration with stakeholders intended to help organizations identify and manage privacy risk to build innovative products and services while protecting individuals' privacy."

Privacy framework progress so far…

- NIST approach has been approved by the ORCID senior team… but…
- My focus so far has been on documentation and completing outstanding work
- Aiming for closer alignment with framework (and associated security / AI frameworks?) over time
- We will continue to be responsive to data protection needs and not ‘process bound’

The ORCID Privacy Policy

POLL: Do you always read organisation's privacy policies / notices?

A. Of course I do! Every single time
B. I read them if I feel I need to (e.g. for work or personal reasons)
C. Only if I have a complaint or concern about the organisation
D. No way, who has time for that?!

Privacy Policies: the problem

Q: Are they fun to read?

A: Not normally

Q: Do we want people to read them?

A: Actually, yes! (but we think mostly they don't)

Q: Do we need to have one?

A: It depends, but increasingly yes

BBC Sign in Home News Sport Weather

NEWS

Home | InDepth | Israel-Gaza war | US election | Cost of Living | War in Ukraine | Climate | UK | W

World | Africa | Asia | Australia | Europe | Latin America | Middle East | US & Canada

Free wine hidden in small print claimed after three months

A free bottle of wine has finally been claimed after being hidden in the privacy policy of a tax-focused think tank's website for three months.

Tax Policy Associates added the clause in February as an experiment, to see if anyone would actually read the full terms.

The non-profit organisation's head Dan Neidle shared the story in a **tweet on X**, formerly Twitter, saying the first person to spot it would get sent a "bottle of good wine".

Mr Neidle - who has **previously reported on high-profile tax cases**, including that of former Chancellor Nadhim Zahawi - told the BBC it was his idea to add the wine offer.

The business has recently changed the small print **on its site** after the eagle-eyed discovery.

"We know nobody reads this, because we added in February that we'd send a bottle of good wine to the first person to contact us, and it was only in May that we got a response," a sentence in their privacy policy now reads.

Mr Neidle said it was "my childish protest that all businesses have to have a privacy policy and no one reads it".

Why we think privacy policies are important

- We want to be open and transparent (there's nothing to hide!)
- We know we have legal obligations to fulfil
- We want a resource that we - and others - can refer to as needed
- It's how most people find out about their data rights
- It's our privacy 'shop window' and we want others to know that we take this stuff seriously

Why we wanted to do a full review and rewrite

- Last revisions were in 2021
- We knew that we had other data uses to tell people about (e.g. events)
- Not everything we do is based on consent - some data we just have to use in order to operate (e.g. providing tech support)
- ‘Typical’ privacy policies had moved on since we first created ours
- We had the time and resource to do it
- It’s a great way to check we’re doing what we think we’re doing

What we were aiming for

- Comprehensive explanation of what we do with people's data
- Clarity (easy to understand, logical structure)
- To meet legal requirements (but not be too legalistic)
- To give greater prominence to data subject rights
- To meet the expectations and needs of all the ORCID community

What you get (we hope!)

We try to put direct choice and control in your hands as much as possible. Where this is not possible, we still want you to be knowledgeable and empowered about our data use. The policy helps with this.

- We want you to know your rights, and how we will uphold them
- We want you to engage with us about how we use data
- We want it to be a resource you can refer to, and tell others about

Did we achieve our aims?

- It's quite long…
- …but it is comprehensive
- It is clear…
- …but it's still not a 'fun read'

- We're meeting all the legal obligations we know of…
- …but privacy laws are changing and there probably is still a US/EU focus

POLL: What do you think about our new policy?

A. I like it!
B. I haven’t yet read it but I will now (or when I have a need to)
C. It does what it needs to do but I think you could still make improvements
D. I really don’t like it

If you have any comments or suggestions…

Please tell us!

privacy@orcid.org

Data Protection Rights

ORCID's approach to data subject rights

As inclusive as possible

Regardless of where someone is in the world, we will aim to uphold all the rights listed in our privacy policy

As 'self-service' as possible

We don't want to put barriers in people's way. We will only handle a request or complaint 'formally' where there is no other reasonable option

As fair and transparent as possible

We aim to fulfil all requests but if we cannot do so we will explain why, and give details of any routes for escalation or complaint

How people can exercise their data rights

- As far as possible, we want people to be in direct control of how their data is used
- We have lots of guidance on our website and help pages
- We have internal processes for handling data requests and complaints
- Contact privacy@orcid.org

Privacy and Security at ORCID

We can’t do privacy without security

The cybersecurity and data protection overlap
You can have security without personal data, but you can’t have data protection without security

ORCID is doing both
Alongside our data protection improvements we’re currently running a cybersecurity program of work. Each will inform and strengthen the other

People are key
Although cybersecurity work is often more technical in nature than data protection, both rely on people in order to work successfully. Training and having a privacy and security-aware culture are essential

What’s next?

Where we want to go

We are committed to upholding privacy rights and to the protection of personal information in our care.

We aim to understand and respect the privacy needs of all ORCID users, employees and stakeholders

How we are going to get there

- **Keep working on the Privacy Framework**
- **Maintain focus and a culture that understands and values personal data**
- **Keep up to date with changes to privacy laws**
- **Keep listening to you!**

The text of this presentation is published under a CC0 waiver.
Images and marks may be subject to copyright and trademark protection.